

Introduction

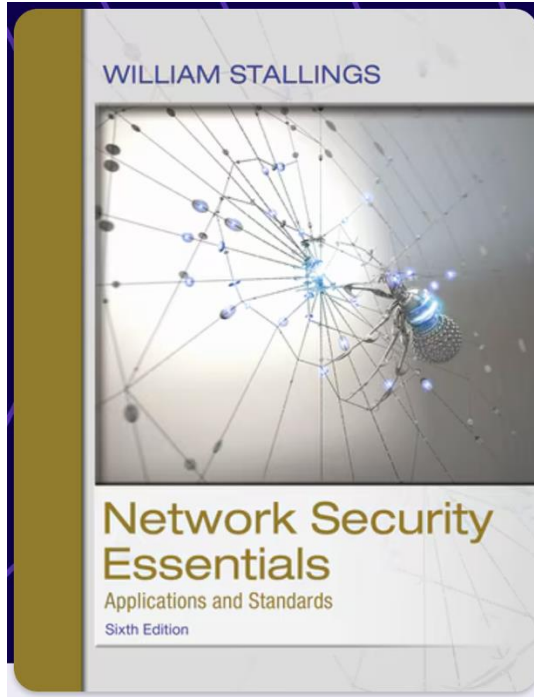
Dr. Yiwen Hu

Announcement

- After class today, our TA will stay here to answer questions
 - if you missed the first class and have any questions about the course
 - if your project group needs help
 - ...

Feel free to stay and talk to our TA (Haitian, my PhD student)

Acknowledgement



You can find it on Blackboard

The content of slides is from the textbook and Dr. Hu's supplementary materials

Reminder: Please do not post course materials online or share them with others without the instructor's permission

Outline

- Computer security concepts and key objectives
- Computer security challenges
- Computer security terminologies
 - Vulnerabilities, threats, and attacks
- 12 fundamental security design principles



The NIST computer security handbook defines Computer Security as:

- The protection afforded to an automated information system in order to attain the applicable objectives of preserving the **Integrity, Availability, and Confidentiality** of information system resources including
 - Hardware, software, firmware, information, data
 - Communications

NIST: National Institute of Standard Technology

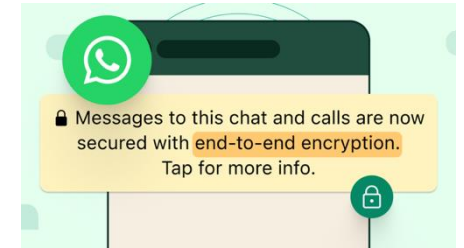
<http://csrc.nist.gov/publications/nistpubs/800-12/handbook.pdf>



NIST: The **Key Objectives** of confidentiality, integrity, and availability (NIST)

- **Confidentiality**

- **Data confidentiality** - Assures that private or confidential information is not made available or disclosed to unauthorized parties
- **Privacy** - Assures that individuals can control or influence what information related to them may be collected and stored and by whom and to whom that information may be disclosed.



NIST: National Institute of Standard Technology

<http://csrc.nist.gov/publications/nistpubs/800-12/handbook.pdf>



NIST: The **Key Objectives** of confidentiality, integrity, and availability (NIST)

- **Integrity**

- **Data integrity** - Assures that information and programs are changed only in a specified and authorized manner
- **System integrity** - Assures that a system performs its intended functions in an unimpaired manner, free from deliberate or inadvertent unauthorized manipulation of the system

NIST: National Institute of Standard Technology

<http://csrc.nist.gov/publications/nistpubs/800-12/handbook.pdf>



NIST: The **Key Objectives** of confidentiality, integrity, and availability (NIST)

- **Availability**

- Assures that systems work promptly and service is not denied to authorized users
- The Classic Threat: DoS Attacks

NIST: National Institute of Standard Technology

<http://csrc.nist.gov/publications/nistpubs/800-12/handbook.pdf>



Questions

Options:

A) Integrity

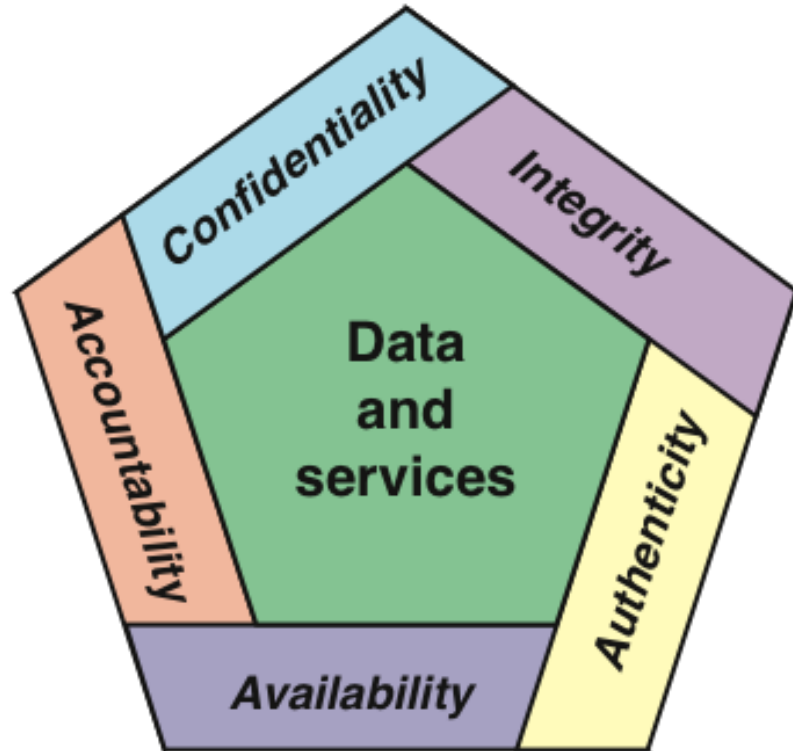
B) Confidentiality

C) Availability

Which security principle is primarily involved?

- An unauthorized student gains access to the school's digital gradebook. They don't change any numbers, but they download a list of everyone's GPA and post it on social media
- A group of hackers floods a retail website with so much fake traffic that legitimate customers cannot load the page to buy products
- A disgruntled employee logs into the company's "About Us" page and changes the CEO's biography to include several insults and false work history

Authenticity & Accountability



- **Authenticity**

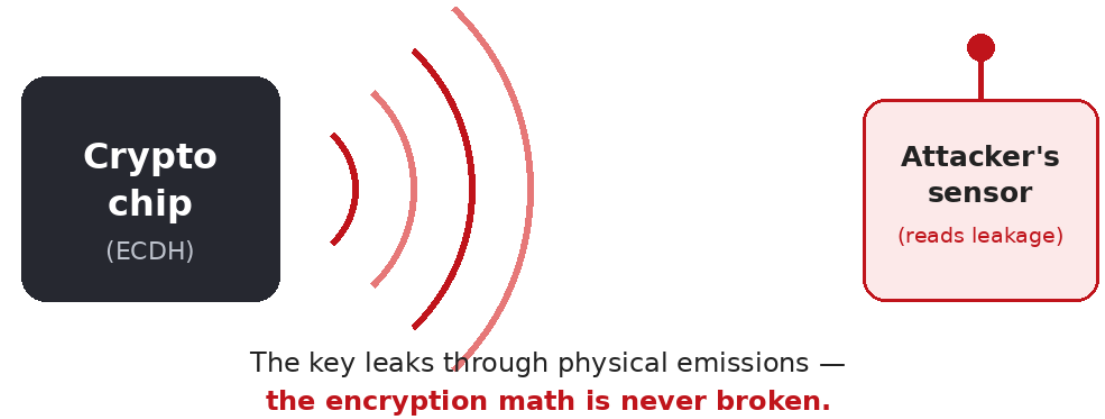
- Verifying that users are who they say they are and that each input arriving at the system came from a trusted source

- **Accountability**

- The security goal that generates the requirement for actions of an entity to be traced uniquely to that entity

Nine computer security challenges

- Computer security is not as simple as it might first appear to the novice



- Potential attacks on the security features must be always considered. Thus, procedures used to provide particular services are often counterintuitive (designs are not straightforward)
- Security mechanisms typically involve more than a particular algorithm or protocol

Nine computer security challenges

- Physical (e.g., on a network host) and logical (e.g., in a network/link layer) placement needs to be determined
- Attackers only need to find a single weakness. However, the system administrator needs to find all weaknesses (**hard to defend**)
- Users and system managers tend to not see the benefits of security until a failure occurs (**have no support**)

Nine computer security challenges

- Security requires regular and constant monitoring
- Is often an afterthought to be incorporated into a system after the design is completed (**giving patches cannot fundamentally address issues**)
- Thought of as an impediment to efficient and user-friendly operations (**users dislike complicated security mechanisms**)

Computer Security Terminology (RFC 4949)

- **Vulnerability** - A flaw or weakness in a system's design, implementation, or operation and management that could be exploited to violate the system's security policy.
- **Threat** - A potential for violation of security, which exists when there is a circumstance, capability, action, or event, that could breach security and cause harm. That is, a threat is a possible danger that might exploit a vulnerability.
- **Attack** - An assault on system security that derives from a threat; that is, an intelligent act that is a deliberate attempt (especially in the sense of a method or technique) to evade security services and **carry out the threat**.



The Relationship:

Vulnerability: The hole in the fence

Threat: The wolf in the woods

Attack: The wolf actually jumping through the hole to get to the sheep



Question:

- **Security policy (The Objective):** To prevent unauthorized entry, all residents must use a unique, app-generated QR code to unlock the dormitory main gate

Q1. The mobile app generates a static QR code that remains valid for 10 minutes and does not have "anti-screenshot" protection

Options:

- A) Vulnerability
- B) Threat
- C) Attack

Questions

Options:

A) Vulnerability

B) Threat

C) Attack

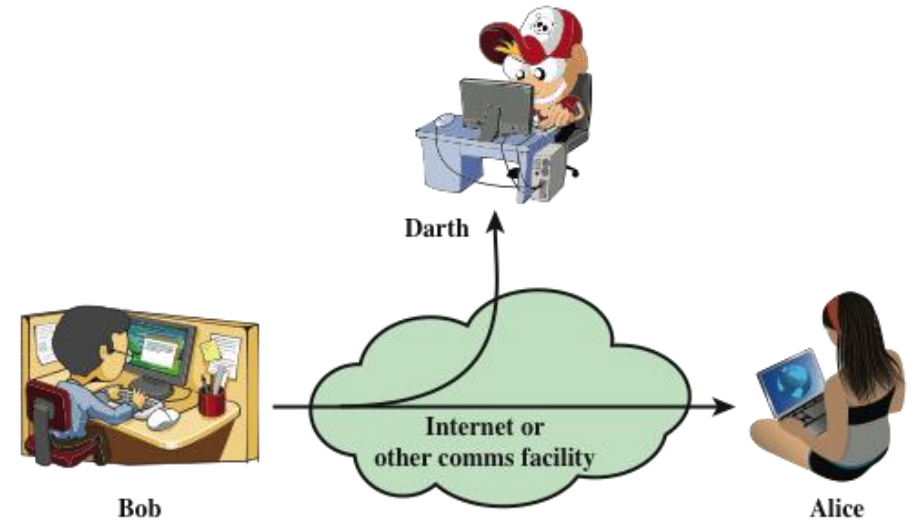
Q2. Unidentified individuals (e.g., unauthorized delivery drivers or suspicious strangers) who want to bypass the gate to access student living quarters

Q3. Steps:

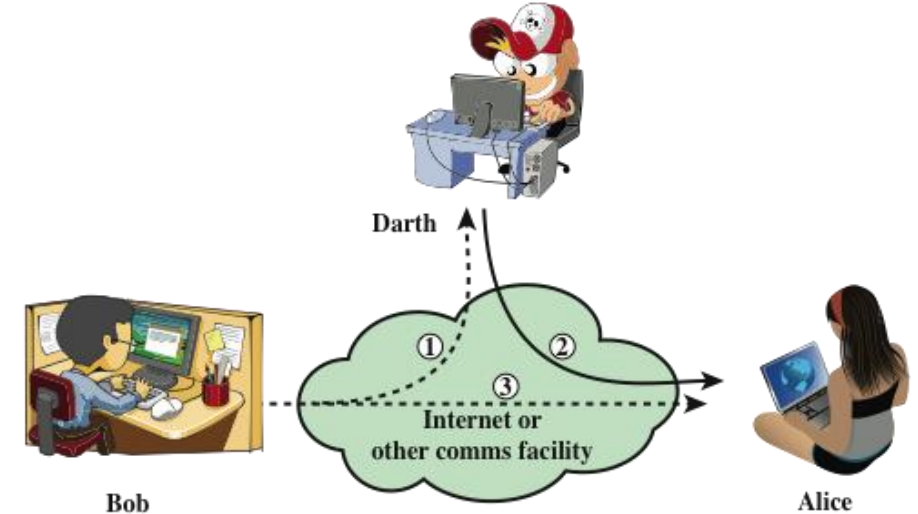
- 1. A stranger waits at the gate and asks a student: "Can you screenshot your code and text it to me? I forgot my phone and need to get in."
- 2. The student sends the screenshot via a messaging app (Social Engineering).
- 3. The stranger scans the screenshot at the reader.
- 4. The system identifies the code as valid, unlocks the door, and the stranger enters undetected

Security Attacks

- A **passive attack** attempts to learn or make use of information from the system but does not affect system resources
- An **active attack** attempts to alter system resources or affect their operation



(a) Passive attacks



(b) Active attacks

Passive attacks

- Are in the nature of eavesdropping on, or monitoring of, transmissions
- Two types of passive attacks are:
 - The release of message contents
 - Traffic analysis



Active attacks

- Involve some modification of the data stream or the creation of a false stream
- Difficult to prevent because of the wide variety of potential physical, software, and network vulnerabilities

Masquerade

- Takes place when one entity pretends to be a different entity
- Usually includes one of the other forms of active attack

Replay

- Involves the passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect

Modification of messages

- Some portion of a legitimate message is altered, or messages are delayed or reordered to produce an unauthorized effect

Denial of service

- Prevents or inhibits the normal use or management of communications facilities

12 fundamental security design principles

1 Economy of mechanism

2 Fail-safe defaults

3 Complete mediation

4 Open design

5 Separation of privilege

6 Least privilege

7 Least common mechanism

8 Psychological acceptability

9 Isolation

10 Modularity

11 Layering (defense in depth)

12 Least astonishment

12 fundamental security design principles

- **Economy of mechanism:** the design of security measures should be as simple and small as possible
 - Easier to test and verify thoroughly
 - Fewer flaws
- **Fail-safe default:** the access decisions are based on permission rather than exclusion
 - e.g., default mechanism to deny accesses, the protection scheme identifies conditions under which access is permitted
- **Complete mediation:** every access must be re-checked rather than rely on access decisions retrieved from cache
 - You can refer it to as Zero Trust security model, which has been adopted in DoD communications, Google, etc.

12 fundamental security design principles

- **Open design:** the design of security mechanism should be open rather than secret (it can be reviewed by many experts).
 - E.g., encryption keys must be secret, but encryption algorithms should be open to the public
- **Separation of privilege:** multiple privileges are required to access a system resource or complete a task
 - Mitigate damages if a privilege is compromised
- **Least privilege:** every process and every user should be only granted with the least set of privileges required to perform the task
 - Prevent abusing

12 fundamental security design principles

- **Least common mechanism:** minimize the functions shared by different users/processes/tasks, providing mutual security
 - Every shared mechanism is a potential communication path (E.g., process A leaks some critical information to process B which has no proper permissions to access)
- **Psychological acceptability:** the security mechanisms should not interfere with the work of users, while at the same time meeting the needs of those who authorize access
 - Otherwise, users will disable them (e.g., Kaspersky's password input box may be a case)
- **Isolation**
 - Public access systems are isolated from critical resources
 - Process and files of individual users are isolated from one another
 - Security mechanisms should be isolated in the sense of preventing access to other security mechanisms

12 fundamental security design principles

- **Modularity:** develop security functions as separate, protected modules and use a modular architecture for design and implementation
 - E.g., all of IPSEC, TLS, SSL protocols require cryptographic functions. We develop it as a separate cryptographic module which can be used by Internet protocols
- **Layering (defense in depth):** adopt multiple, overlapping protection approaches
 - The failure of any protection will not leave the system unprotected
- **Least astonishment:** user interface responds in the way that is least likely astonish users
 - E.g., authorization mechanism should be transparent to users.

The Hidden Cost of Vibe Coding: Supply-Chain Attacks

- You don't write all your code — AI pulls in dozens of libraries you never read
- A **supply-chain attack** hides malicious code inside a trusted package
- One poisoned dependency → every app that installs it ships the backdoor
- Real case: the xz backdoor (2024) — nearly slipped into Linux worldwide

Supplementary information – Where to find discovered security vulnerabilities?

- Open Vulnerability Database
 - <https://cve.mitre.org/>
 - E.g., Wi-Fi router leaks your Wi-Fi access password, <http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2019-7746>
- Top four security conferences
 - [IEEE S&P](#), [ACM CCS](#), [USENIX Security](#), [NDSS](#)
- Top networking conferences/journals
 - [SIGCOMM](#), [MOBICOM](#), [NSDI](#), [ToN](#), [TMC](#)
- Top mobile/embedded system conferences
 - [MobiSys](#), [SenSys](#)
- Popular hacking conferences
 - <https://hack.lu/>
 - <http://www.blackhat.com/>